

WEEKLY INTERNSHIP REPORT

Week Report - Rule Validation and NAT Source-IP Troubleshooting Phase

Design and Implementation of an IDS/IPS-Based SOC Platform for Detecting and Preventing Broken Access Control Attacks in REST APIs

Student	Bui Tat Dat
Major	Cyber Security
Main target	crAPI vulnerable API laboratory
Monitoring platform	Wazuh Manager, Wazuh Indexer, and Wazuh Dashboard
Detection focus	BOLA/IDOR, BFLA, REST method abuse, authentication abuse, SSRF, SQLi/NoSQLi, JWT bypass heuristic, Mass Assignment, and router/-NAT visibility
Current status	Custom rules and Wazuh logtest scripts are validated; live log source-IP preservation is under troubleshooting because the Kali attacker IP 10.10.1.20 is translated into the Docker/local address 172.20.0.2.
Supervisor	Tran Dai Duong
Organization	Company / Internship Organization

Abstract

This weekly report documents the progress made after the previous detection-engineering report. The previous week established the main SOC laboratory workflow: crAPI produces web/API logs, Wazuh agents collect logs, Wazuh Manager applies custom rules, Wazuh Indexer stores alerts, and Wazuh Dashboard is used by the analyst to review suspicious API behavior. The previous evidence showed that high-severity BOLA/IDOR vehicle-location attempts could appear in Wazuh Dashboard, but several categories still required stronger row-level validation.

This week, the project moved from partial dashboard evidence to systematic rule validation. The custom Wazuh rule file was consolidated into a broader bGlobal/crAPI rule set covering BOLA/IDOR object access, UUID-based vehicle-location access, REST method abuse, BFLA/admin endpoint probing, sensitive path probing, authentication failures and scanning, SSRF, SQLi/NoSQLi, JWT `alg:none` indicators, and Mass Assignment/BOPLA indicators. Two validation scripts were used. The broader regression script executed 21 rule tests and all 21 passed. The focused rule-test script executed 23 rule checks and all 23 passed. These results show that the rule patterns, parent Wazuh rule dependencies, HTTP status-code matching, and correlation logic can match the expected synthetic log events.

The main limitation this week is not the XML rule matching itself. The remaining blocker is live traffic attribution in the Docker/NAT path. The attack machine is the Kali host 10.10.1.20, but the logs visible to the web layer are returning the translated local/Docker address 172.20.0.2. This means URL-based detections can still match, but source-IP attribution and `same_srcip` correlation may point to the Docker router or bridge address instead of the real attacking host. Therefore, the current status is: rule logic validated, dashboard/live traffic validation partially blocked by source-IP preservation, and router pre-NAT logging or proxy header/log-format tuning is required before final detection evaluation.

Keywords: SOC, Wazuh, crAPI, API Security, Broken Access Control, BOLA, IDOR, BFLA, SSRF, SQL Injection, JWT, Mass Assignment, Docker NAT, Source IP Preservation, Detection Engineering.

Contents

Abstract	i
List of Acronyms	vi
1 Weekly Progress Overview	1
1.1 Purpose of This Weekly Report	1
1.2 Completed Work This Week	1
1.3 Current Project Status	2
1.4 Main Result	2
2 Lab Architecture and Current Logging Path	4
2.1 SOC Laboratory Architecture	4
2.2 Current Source-IP Problem	4
2.3 Why This Is Not a Rule-Matching Failure	5
3 Custom Wazuh Rule Engineering	6
3.1 Rule File Organization	6
3.2 Detection Categories	6
3.3 Rule Severity Model	7
3.4 Example: BOLA and Vehicle-Location Detection	8
3.5 Router and NAT Visibility Rules	8
4 Rule-Test Validation Evidence	10
4.1 Validation Methodology	10
4.2 Regression Test: 21 Passed, 0 Failed	10
4.3 Focused Rule Test: 23 Passed, 0 Failed	11
4.4 Validation Matrix	11
4.5 Interpretation of Test Results	12
5 Live Log Source-IP Issue	13
5.1 Observed Behavior	13
5.2 Likely Technical Cause	13
5.3 Impact on Detection Engineering	13
5.4 Current Assessment	14
6 Recommended Fix Plan	15

6.1	Fix Option 1: Collect Pre-NAT Router Logs	15
6.2	Fix Option 2: Preserve Client IP Through Reverse Proxy Headers	15
6.3	Fix Option 3: Avoid Source NAT in the Lab Path	16
6.4	Fix Option 4: Correlate Router Logs and Web Logs	16
7	SOC Triage Interpretation	17
7.1	How an Analyst Should Interpret the Current Alerts	17
7.2	Example Triage Worksheet	17
8	Limitations and Risk of Overclaiming	19
8.1	What Is Confirmed	19
8.2	What Is Not Fully Confirmed Yet	19
8.3	Remaining Technical Limitations	19
9	Plan for Next Week	21
9.1	Engineering Tasks	21
9.2	Expected Deliverables for Next Report	21
10	Conclusion	23
A	Appendix: Evidence Summary	24
A.1	Key Rule-Test Commands	24
A.2	Recommended Dashboard Fields	24
A.3	Source-IP Verification Checklist	24
B	Appendix: Rule Coverage Matrix for Report Evidence	26
	References	28

List of Tables

1.1	Current weekly project status	2
3.1	Parent web-access rule usage	6
3.2	Implemented Wazuh rule categories and validation state	6
3.3	Severity model used in the custom rule set	8
4.1	Expected rule ID versus validation outcome	11
5.1	Impact of the source-IP mismatch	13
7.1	Example triage worksheet for this week's issue	17
8.1	Current technical limitations and remediation direction	20
9.1	Expected deliverables for the next weekly report	21
A.1	Checklist for source-IP verification	24
B.1	Final evidence matrix to fill after live retesting	27

List of Figures

2.1	Current SOC lab workflow for crAPI API-attack detection.	4
2.2	Difference between expected Kali source IP and observed Docker/local source IP.	5

List of Acronyms

Acronym	Meaning
API	Application Programming Interface
BAC	Broken Access Control
BFLA	Broken Function Level Authorization
BOLA	Broken Object Level Authorization
BOPLA	Broken Object Property Level Authorization
DFIR	Digital Forensics and Incident Response
DQL	Dashboard Query Language, used in Wazuh Dashboard Discover
IDOR	Insecure Direct Object Reference
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
JWT	JSON Web Token
NAT	Network Address Translation
SIEM	Security Information and Event Management
SOC	Security Operations Center
SSRF	Server-Side Request Forgery
XDR	Extended Detection and Response

1 Weekly Progress Overview

1.1 Purpose of This Weekly Report

The purpose of this report is to continue the previous weekly report and document the new progress of the SOC/IDS project. Last week, the report focused on the transition from system setup to detection engineering, including controlled pentesting, custom rule writing, Wazuh Dashboard validation, and the limitation that not every attack category had dashboard-confirmed evidence.

This week focuses on a more precise engineering question: whether the custom Wazuh rules actually match the expected events, and whether live traffic carries the correct attacker source IP into the logs. The rule-matching result is positive. The source-IP visibility result is still incomplete because the Kali attacker IP 10.10.1.20 is not preserved in the web-layer log. Instead, the event is observed as 172.20.0.2, which appears to be a Docker/local network address introduced by routing or NAT.

1.2 Completed Work This Week

The completed work this week is summarized below.

1. The custom bGlobal/crAPI Wazuh rule set was moved to the Wazuh server side so that rule validation is performed at the correct analysis layer rather than only inside the crAPI agent-side folder.
2. The rule file was expanded and consolidated with detection categories for BOLA/IDOR, UUID vehicle-location access, REST method abuse, BFLA/admin probing, sensitive path probing, authentication abuse, SSRF, SQLi/NoSQLi, JWT bypass heuristic, Mass Assignment/BOPLA, and router/NAT visibility.
3. The script `test_bglobal_wazuh_rules.sh` was executed successfully. It ran 21 tests, including individual attack-pattern checks and correlation-rule checks. All 21 tests passed.
4. The script `test_mynew_rule.sh` was executed successfully. It ran 23 focused rule tests. All 23 tests passed.
5. Rule-level detection is now more reliable than the previous week because rule matching is proven through `wazuh-logtest`-style validation rather than only dashboard observation.

6. The remaining live-log issue was identified clearly: the attacker IP should be 10.10.1.20, but the observed source IP becomes 172.20.0.2. This affects source attribution and source-based correlation.
7. Router/NAT visibility rules were added to identify pre-NAT traffic and specifically match SRC=10.10.1.20 when such pre-NAT router logs are collected.

1.3 Current Project Status

Table 1.1: Current weekly project status

Task	Status	Notes
System setup	Validated	The crAPI and Wazuh laboratory base has already been implemented from the previous phase.
Wazuh agent layer	Validated	Agents are available for log collection. The issue is now about which log source preserves the original attacker IP.
Custom Wazuh rules	Validated	The XML rules are implemented and pass synthetic rule validation.
Rule regression testing	Validated	<code>test_bglobal_wazuh_rules.sh</code> : 21 passed, 0 failed. <code>test_mynew_rule.sh</code> : 23 passed, 0 failed.
Correlation logic	Validated	Correlation rules such as repeated BOLA, repeated UUID vehicle-location access, repeated auth failures, and repeated BFLA probing passed the regression test.
Live dashboard validation	In Progress	URL and status based detections can still work, but source-IP attribution is not correct yet.
Source-IP preservation	In Progress	Kali IP 10.10.1.20 is expected, but live logs show 172.20.0.2. This is the main blocker.
Router/NAT visibility	In Progress	Router rules were added, but they require real pre-NAT log ingestion from the network-router container or host firewall path.
DFIR/IR case automation	Pending	Should be started after detection identity and source-IP evidence are stable.

1.4 Main Result

The main result is that the custom Wazuh detection logic is now validated at the rule-test level. Last week, several categories remained only partially confirmed because dashboard screenshots did not show every rule. This week, the test scripts confirm that the rules can produce the

expected final rule IDs for the target attack patterns. However, this does not yet mean that every live attack event is fully validated in the dashboard. The live source-IP issue must be fixed before the report can claim reliable attacker attribution.

2 Lab Architecture and Current Logging Path

2.1 SOC Laboratory Architecture

The laboratory still follows the same high-level SOC architecture. The tester or attacker generates requests against crAPI. The web/API layer writes logs. Wazuh collects and decodes those logs. Custom rules generate alerts. The analyst reviews the alerts in Wazuh Dashboard.

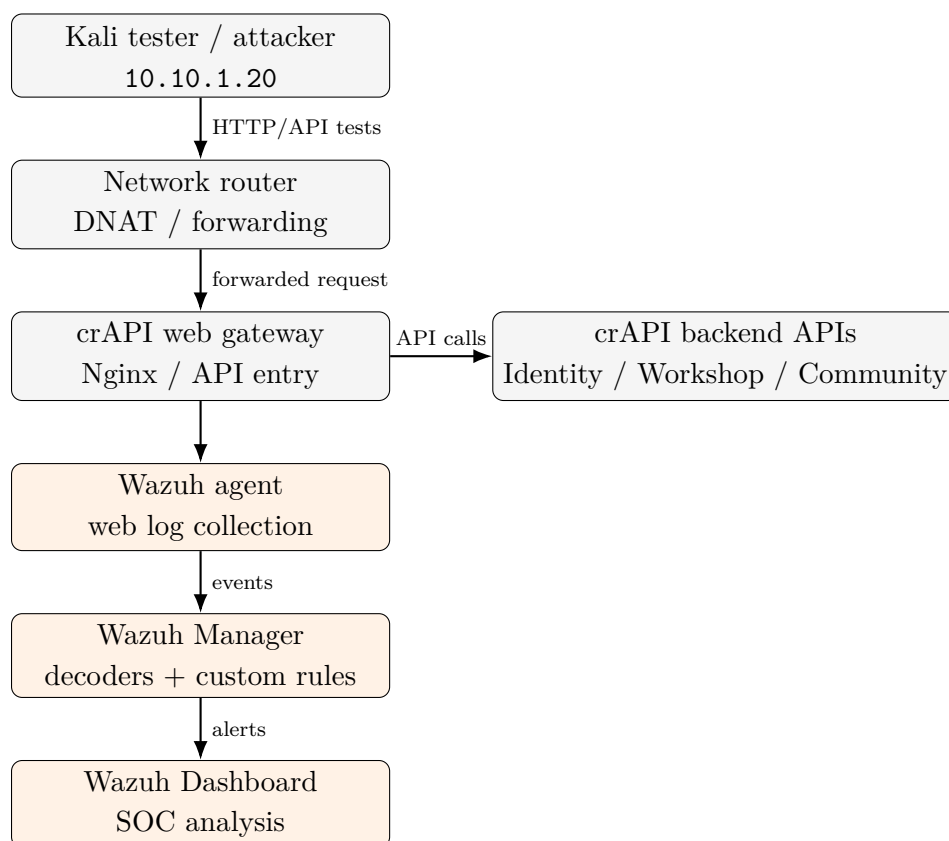


Figure 2.1: Current SOC lab workflow for crAPI API-attack detection.

2.2 Current Source-IP Problem

The current problem is that the attacker host and the application log disagree about the source IP. The real attacker/tester is the Kali host 10.10.1.20. The Wazuh event or collected

web log instead shows 172.20.0.2. This usually happens when the log is collected after a NAT, Docker bridge, reverse proxy, or container-to-container forwarding step. From the application perspective, the immediate client is not always the real Kali host; it can be the router/proxy/container address.

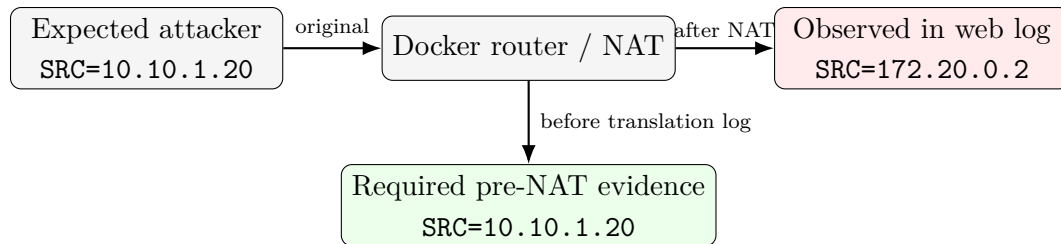


Figure 2.2: Difference between expected Kali source IP and observed Docker/local source IP.

2.3 Why This Is Not a Rule-Matching Failure

The source-IP problem should be separated from XML rule correctness. The test results show that the Wazuh rules can match the expected URLs, methods, response codes, and correlation conditions. The remaining issue is the quality of the live log field used as `data.srcip`. If `data.srcip` is already rewritten to 172.20.0.2, then Wazuh is correctly processing the log it receives, but the log itself has lost the original attacker identity.

3 Custom Wazuh Rule Engineering

3.1 Rule File Organization

The rule file is organized under the main group `bglobal,crapi,api,broken_access_control`. The rules use Wazuh web access log parents and then add more specific conditions for URL patterns, status codes, HTTP methods, and repeated behavior.

The most important parent rule strategy is shown in Table 3.1.

Table 3.1: Parent web-access rule usage

Parent SID	Response class	Use in this project
31108	2xx / 3xx	Used when successful or redirected access to suspicious API endpoints should be detected.
31101	4xx	Used when failed, denied, missing, or unauthorized access still represents attack intent.
31122	5xx	Used when a suspicious request causes server-side error behavior.

3.2 Detection Categories

Table 3.2: Implemented Wazuh rule categories and validation state

Category	Rule IDs	Validation status	Detection meaning
BOLA numeric / UUID object access	110100, 110104, 110105, 110101	Validated	Detects object identifier access and repeated object access from the same source.
UUID vehicle- location BOLA	110120, 110121, 110122	Validated	Detects access to <code>/identity/api/v*/vehicle/<UUID>/location</code> and repeated enumeration.
REST method abuse	110130, 110131	Validated	Detects PUT, PATCH, and DELETE against object endpoints.

Category	Rule IDs	Validation status	Detection meaning
BFLA/admin probing	110400, 110401, 110402	Validated	Detects access or probing of admin, internal, management, actuator, and server-status paths.
Sensitive path probing	110102, 110106, 110107, 110103	Validated	Detects suspicious discovery of paths such as <code>/.env</code> , <code>/.git</code> , <code>/swagger</code> , and <code>/api-docs</code> .
Authentication abuse	110200, 110206, 110201, 110202, 110203, 110204, 110205	Validated	Detects failed authentication, auth endpoint scanning, and repeated login-like activity.
SSRF	110300, 110301	Validated	Detects contact-mechanic requests containing loopback, metadata, or private IP indicators in visible URL/query data.
SQLi / NoSQLi	110310, 110311	Validated	Detects common SQLi and NoSQLi tokens in URL/query strings.
JWT bypass heuristic	110500, 110501	Validated	Detects visible <code>alg:none</code> and base64 JWT header indicators.
Mass Assignment / BOPLA	110510, 110511	Validated	Detects suspicious over-posting property indicators such as role, admin, balance, wallet, and permissions.
Router / NAT visibility	111000, 111001, 111010	In Progress	Rules are implemented, but live pre-NAT router log ingestion still needs to be confirmed.

3.3 Rule Severity Model

The severity model remains consistent with the previous report but is now supported by automated rule tests.

Table 3.3: Severity model used in the custom rule set

Level range	Meaning	SOC handling
3 to 6	Low-confidence or contextual signal	Keep for context, correlation, and timeline reconstruction.
8 to 9	Suspicious request pattern	Review during hunting; useful for attack-surface discovery and dashboard trend analysis.
10	High-confidence suspicious behavior	Investigate source IP, URL, method, response code, and related events.
11 to 13	Repeated or correlated behavior	Treat as incident candidate; consider triage escalation, blocking, or case creation.

3.4 Example: BOLA and Vehicle-Location Detection

The vehicle-location rule set remains the clearest example of broken object-level access monitoring. A single failed request to an object-specific vehicle-location endpoint is suspicious because it targets a sensitive object path. Repeated requests from the same source become stronger evidence of enumeration.

Listing 3.1: Selected BOLA/IDOR vehicle-location rules

```
<rule id="110121" level="10">
  <if_sid>31101</if_sid>
  <id>^(401|403|404)$</id>
  <url type="pcre2">(?!i)~/identity/api/v[0-9]+/vehicle/[0-9a-f]{8}-[0-9a-f]{4}-[0-9a-f]{4}-[0-9a-f]{4}-[0-9a-f]{12}/location(?:/)?(?:\?.*)?</url>
  <description>bGlobal: Possible BOLA/IDOR - Failed Vehicle Location Object Access</description>
  <group>bglobal,crapi,api,broken_access_control,bola_uuid_access,</group>
</rule>

<rule id="110122" level="13" frequency="5" timeframe="120" ignore="300">
  <if_matched_group>bola_uuid_access</if_matched_group>
  <same_srcip />
  <description>bGlobal: Possible BOLA/IDOR Enumeration - Repeated Vehicle Location Object Access</description>
  <group>bglobal,crapi,api,broken_access_control,bola_uuid_access,correlation,</group>
</rule>
```

3.5 Router and NAT Visibility Rules

A new part of the rule set focuses on observing router-side logs before NAT changes the source IP. These rules are important because the web layer currently sees 172.20.0.2 instead of 10.10.1.20.

Listing 3.2: Router and NAT visibility rules

```
<rule id="111000" level="5">
  <match>CRAPI_WEB_IN</match>
  <description>crAPI router observed inbound web traffic before NAT</description>
  <group>bglobal,crapi,router,network,nat,docker,soc,router_web,</group>
</rule>

<rule id="111001" level="5">
  <match>CRAPI_MAIL_IN</match>
```

```
<description>crAPI router observed inbound MailHog traffic before NAT</description>
<group>bglobal,crapi,router,network,nat,docker,soc,router_mail,</group>
</rule>

<rule id="111010" level="10">
  <if_sid>111000,111001</if_sid>
  <match>SRC=10.10.1.20</match>
  <description>crAPI lab attacker Kali host observed at router before NAT</description>
  <group>bglobal,crapi,router,network,nat,docker,soc,kali_attacker,</group>
</rule>
```

The purpose of these rules is not to replace the API rules. They add a network-observation layer. The API rules explain what endpoint was targeted. The router rules can prove who contacted the exposed service before address translation.

4 Rule-Test Validation Evidence

4.1 Validation Methodology

This week, validation was performed through controlled Wazuh rule tests. The rule tests submit representative log lines to Wazuh rule evaluation and compare the expected final rule ID with the actual final rule ID. This method is useful because it isolates rule logic from live network noise.

The validation answers three questions.

1. Does the rule file load correctly on the Wazuh server side?
2. Does each test log line match the expected Wazuh rule ID?
3. Do correlation rules fire when repeated events from the same source appear within the configured timeframe?

4.2 Regression Test: 21 Passed, 0 Failed

The first script, `test_bglobal_wazuh_rules.sh`, tested 21 rule scenarios. It included both single-event detections and correlation rules. The result was 21 passed and 0 failed.

Listing 4.1: Summary from the bGlobal Wazuh rule regression script

PASS 1	BOLA numeric object access 2xx	expected=110100	actual=110100
PASS 2	BOLA numeric object access 4xx	expected=110104	actual=110104
PASS 3	BOLA with crAPI identity prefix	expected=110104	actual=110104
PASS 4	UUID vehicle location 2xx	expected=110120	actual=110120
PASS 5	UUID vehicle location 403	expected=110121	actual=110121
PASS 6	Sensitive path probing .env	expected=110106	actual=110106
PASS 7	Swagger/API docs probing	expected=110106	actual=110106
PASS 8	Auth failure	expected=110200	actual=110200
PASS 9	Auth endpoint scanning	expected=110204	actual=110204
PASS 10	BFLA admin successful access	expected=110400	actual=110400
PASS 11	BFLA admin probing	expected=110401	actual=110401
PASS 12	REST method abuse DELETE	expected=110131	actual=110131
PASS 13	REST method abuse PATCH	expected=110130	actual=110130
PASS 14	Mass Assignment query indicator	expected=110511	actual=110511
PASS 15	JWT alg none URL/query indicator	expected=110501	actual=110501
PASS 16	SQLi support rule	expected=110311	actual=110311
PASS 17	SSRF support rule	expected=110301	actual=110301
PASS 18	Repeated BOLA object access correlation	expected=110101	actual=110101
PASS 19	Repeated UUID vehicle location correlation	expected=110122	actual=110122
PASS 20	Repeated auth failures correlation	expected=110201	actual=110201
PASS 21	Repeated BFLA/admin probing correlation	expected=110402	actual=110402
Summary			

```
Total tests: 21
Passed tests: 21
Failed tests: 0
```

4.3 Focused Rule Test: 23 Passed, 0 Failed

The second script, `test_mynew_rule.sh`, tested 23 focused cases. It covered 2xx/3xx, 4xx, and 5xx variants for several attack categories. The result was 23 passed and 0 failed.

Listing 4.2: Summary from the focused Wazuh rule-test script

```
===== SUMMARY =====
PASS: 23
FAIL: 0
Full raw output saved to bglobal_wazuh_rule_test_results.log
All tests passed.
```

4.4 Validation Matrix

Table 4.1: Expected rule ID versus validation outcome

Test family	Expected rule IDs	Result	Interpretation
BOLA numeric object access	110100, 110104, 110105	Pass	Object-ID URL matching works for 2xx/3xx, 4xx, and 5xx variants.
BOLA object correlation	110101	Pass	Repeated object access can trigger correlation.
UUID vehicle-location access	110120, 110121	Pass	Vehicle-location BOLA detection works for successful-looking and failed access classes.
UUID vehicle-location correlation	110122	Pass	Repeated UUID-location access can trigger high-severity enumeration logic.
REST method abuse	110130, 110131	Pass	Sensitive methods such as DELETE and PATCH match object endpoints.
Sensitive path probing	110102, 110106, 110107, 110103	Pass	Sensitive discovery paths and repeated probing logic match.

Test family	Expected rule IDs	Result	Interpretation
Authentication abuse	110200, 110201, 110202, 110204	Pass	Auth failure, auth attempt, endpoint scanning, and repeated failures match.
SSRF	110300, 110301	Pass	URL-visible SSRF indicators match 2xx/3xx and 4xx cases.
SQLi / NoSQLi	110310, 110311	Pass	Query-visible injection indicators match.
BFLA/admin probing	110400, 110401, 110402	Pass	Admin/internal/management access and repeated probing match.
JWT alg:none heuristic	110500, 110501	Pass	Visible unsigned-token indicators match.
Mass Assignment / BO-PLA	110510, 110511	Pass	Sensitive property indicators match.
Router/NAT source visibility	111000, 111001, 111010	Not fully live-validated	Rule logic exists, but live pre-NAT log collection must be confirmed.

4.5 Interpretation of Test Results

The rule-test results improve the confidence level compared with the previous report. Last week, the dashboard evidence was strong for vehicle-location BOLA/IDOR but weak or incomplete for SSRF, SQLi/NoSQLi, JWT, Mass Assignment, and BFLA. This week, those rules are no longer only draft logic. They are validated against controlled input lines.

However, `wazuh-logtest` validation and live dashboard validation are not the same. Logtest confirms that the rule logic is correct when the input log contains the expected fields. Live dashboard validation still depends on real log collection, log format, source IP preservation, and whether the payload is visible in the collected log.

5 Live Log Source-IP Issue

5.1 Observed Behavior

The expected attacker identity is the Kali machine at 10.10.1.20. During live testing, the observed source address in the logs is 172.20.0.2. This difference is significant because the project uses source-IP based correlation for repeated behavior, such as `same_srcip` in BOLA enumeration and authentication brute-force logic.

5.2 Likely Technical Cause

The most likely cause is that the log is being captured after address translation or forwarding. The crAPI gateway receives the request from an intermediate container or bridge network address, not directly from the Kali IP. In Docker-based labs, the source can be rewritten when traffic crosses a published port, Docker bridge, NAT table, router container, or reverse proxy path.

This means the web access log is truthful from the viewpoint of the web container, but incomplete from the viewpoint of SOC attribution. The web container sees its immediate peer. The SOC analyst needs the original client.

5.3 Impact on Detection Engineering

Table 5.1: Impact of the source-IP mismatch

Detection nment	compo-	Effect if source IP is 172.20.0.2	Operational risk
Single URL/status rules		Still likely to match because URL, method, and status code are unchanged.	Alert category can be correct, but attacker attribution is weak.
<code>same_srcip</code> correlation		Correlation may group events under 172.20.0.2.	Multiple external clients may collapse into one proxy/router identity.
Router-specific rule 11 1010		Will not match unless the pre-NAT router log contains SRC=10.10.1.20.	The report cannot yet prove that the Kali host was observed at the router layer.

Detection nent	compo-	Effect if source IP is 172.20.0.2	Operational risk
Forensic timeline		Timeline can show attack path, but source identity is ambiguous.	Incident reconstruction is weaker and may not support strong conclusions.
Blocking / response de- cision		Blocking 172.20.0.2 could block a router/proxy instead of the attacker.	Response action may disrupt the lab network path rather than isolate the attacker.

5.4 Current Assessment

The source-IP issue is now the main engineering gap. The custom rule logic should not be rewritten only because 172.20.0.2 appears in the logs. Instead, the log collection point should be improved. The project needs either pre-NAT router logs or a reverse-proxy log format that preserves and forwards the original client IP.

6 Recommended Fix Plan

6.1 Fix Option 1: Collect Pre-NAT Router Logs

The most direct fix is to collect logs at the router before NAT changes the source address. The router can log packets with a prefix such as `CRAPI_WEB_IN`. Wazuh can then match rule 111000 and, when `SRC=10.10.1.20` is present, rule 111010.

Listing 6.1: Example pre-NAT logging concept for the router path

```
# Concept only - adapt interface names and chains to the actual network-router container.
iptables -t mangle -I PREROUTING 1 -p tcp -s 10.10.1.20 --dport 8888 \
  -j LOG --log-prefix "CRAPI_WEB_IN " --log-level 4

# Expected log field pattern for Wazuh rule 111010:
# CRAPI_WEB_IN ... SRC=10.10.1.20 DST=10.10.1.1 ... DPT=8888 ...
```

This option gives the strongest attribution evidence because it records the original source before translation. The limitation is that Docker containers may not expose kernel logs in the same way as a full Linux host. If container kernel logging is not easy to collect, using `ulogd`, `NFLOG`, Docker logs, or host-level firewall logging may be more reliable.

6.2 Fix Option 2: Preserve Client IP Through Reverse Proxy Headers

If the gateway or reverse proxy is the first component that receives the original client connection, it can forward the client IP through headers such as `X-Real-IP` and `X-Forwarded-For`. The access log format can then include these fields.

Listing 6.2: Example Nginx client-IP forwarding and logging concept

```
proxy_set_header X-Real-IP $remote_addr;
proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
proxy_set_header X-Forwarded-Proto $scheme;

log_format crapi_ext '$remote_addr xff="$http_x_forwarded_for" '
  '$request_method $request_uri $status';
access_log /var/log/nginx/access.log crapi_ext;
```

This option works only if the original IP is still available at the proxy. If NAT has already rewritten `10.10.1.20` to `172.20.0.2` before the proxy sees the request, then this approach will preserve the translated address, not the Kali address. In that case, pre-NAT router logging is still required.

6.3 Fix Option 3: Avoid Source NAT in the Lab Path

A cleaner architecture is to avoid source NAT between Kali and crAPI. This may require routing the 10.10.1.0/24 lab network into the Docker networks with static routes, using a macvlan network, using host networking for the router, or changing the route/masquerade rules so that the crAPI gateway can see the real source IP. This is more realistic but also more complex.

6.4 Fix Option 4: Correlate Router Logs and Web Logs

If the web log can only see 172.20.0.2, the SOC can still be improved by collecting both log types.

1. Router pre-NAT log: proves 10.10.1.20->10.10.1.1:8888.
2. Web/API access log: proves which API endpoint, method, and response code were observed.
3. Wazuh correlation: combines router-side source identity with web-side API context using timestamp, destination port, and request rate.

This approach is practical for a SOC report because it separates network attribution from application-layer attack semantics.

7 SOC Triage Interpretation

7.1 How an Analyst Should Interpret the Current Alerts

The current alerts should be interpreted as follows.

1. If a rule such as 110121 fires, the API path and response pattern are suspicious and useful for detection.
2. If `data.srcip` is 172.20.0.2, the analyst should treat it as an intermediate Docker/router address, not necessarily the real attacker.
3. The analyst should search for nearby router/NAT logs containing `CRAPI_WEB_IN` and `SRC=10.10.1.20`.
4. The incident should not claim final attacker attribution until original source IP evidence is collected before NAT.

7.2 Example Triage Worksheet

Table 7.1: Example triage worksheet for this week's issue

Field	Analyst note
Alert category	BOLA/IDOR, BFLA, SSRF, SQLi/NoSQLi, JWT, Mass Assignment, or router/NAT visibility.
Rule ID	Confirm the final <code>rule.id</code> , not only the description.
Observed URL	Record <code>data.url</code> ; this proves the endpoint or payload indicator.
Observed method	Record <code>data.protocol</code> ; needed for REST method abuse.
Response code	Record <code>data.id</code> ; 401/403/404 can still indicate attack intent.
Observed source IP	If 172.20.0.2, mark it as translated/intermediate until proven otherwise.
Expected attacker IP	10.10.1.20. Verify through pre-NAT router logs.
Evidence quality	Rule-test validated, live dashboard partially validated, source attribution pending.

Field	Analyst note
Recommended action	Fix log vantage point, rerun tests, capture row-level dashboard screenshots, then update evidence table.

8 Limitations and Risk of Overclaiming

8.1 What Is Confirmed

The following claims are supported by this week's evidence.

1. The custom Wazuh rule file contains detection logic for the expected API attack categories.
2. The rule set passes automated rule validation with 21/21 passed in the broader regression script.
3. The focused test script passes 23/23 rule checks.
4. Correlation logic works in the synthetic test environment for repeated BOLA object access, repeated vehicle-location access, repeated authentication failures, and repeated BFLA/admin probing.
5. Router/NAT visibility rules have been added to the rule file.

8.2 What Is Not Fully Confirmed Yet

The following claims should not be overstated.

1. The report should not claim that all attack categories are fully validated in Wazuh Dashboard until row-level dashboard evidence is captured for each category.
2. The report should not claim that 10.10.1.20 is visible in the web-layer logs while the observed source is still 172.20.0.2.
3. The report should not treat 172.20.0.2 as the attacker. It should be documented as a translated or intermediate address.
4. The report should not claim final detection accuracy, false-positive rate, or recall until a normal and malicious dataset is built.

8.3 Remaining Technical Limitations

Table 8.1: Current technical limitations and remediation direction

Limitation	Reason	Recommended remediation
Source IP rewritten to 172.20.0.2	Logs are collected after NAT or proxy forwarding.	Add pre-NAT router logs or redesign routing to preserve the original Kali IP.
Some payloads are only in body/header	Default access logs mainly expose URL, method, status, and source.	Add safe application/WAF logs with masking for sensitive fields.
Dashboard evidence incomplete for every category	Rule tests pass, but row-level dashboard screenshots are not yet collected for all categories.	Rerun tests, capture Discover fields, and export evidence per rule family.
Correlation depends on source IP quality	<code>same_srcip</code> is only reliable if <code>data.srcip</code> is reliable.	Fix source-IP preservation before claiming attacker-based correlation.
No final metrics yet	There is not yet a full benign and malicious dataset.	Create baseline normal traffic and attack datasets, then compute coverage and false positives.

9 Plan for Next Week

9.1 Engineering Tasks

The next week should focus on source-IP preservation and live evidence quality.

1. Confirm the exact network path from Kali 10.10.1.20 to crAPI 10.10.1.1:8888 and identify where source NAT occurs.
2. Enable router-side pre-NAT logging with a stable prefix such as `CRAPI_WEB_IN`.
3. Ensure Wazuh collects router logs and test whether rule 111000 fires for inbound crAPI web traffic.
4. Confirm whether rule 111010 fires when the log contains `SRC=10.10.1.20`.
5. Add or tune decoders for router logs if the default Wazuh decoder does not extract `SRC`, `DST`, `SPT`, and `DPT` cleanly.
6. Rerun BOLA/IDOR, BFLA, SSRF, SQLi/NoSQLi, JWT, Mass Assignment, and REST method abuse tests from Kali.
7. Capture row-level Wazuh Dashboard evidence with fields: `agent.name`, `agent.ip`, `data.srcip`, `data.id`, `data.protocol`, `data.url`, `rule.id`, `rule.level`, `rule.description`, and `full_log`.
8. Build a table comparing expected attacker IP, observed web-layer IP, observed router-layer IP, expected rule ID, and observed rule ID.

9.2 Expected Deliverables for Next Report

Table 9.1: Expected deliverables for the next weekly report

Deliverable	Expected value
Router pre-NAT evidence screenshot	Shows <code>SRC=10.10.1.20</code> reaching the crAPI web exposure point.
Wazuh Dashboard row details	Shows exact <code>rule.id</code> , <code>data.url</code> , <code>data.srcip</code> , and <code>full_log</code> .
Rule coverage table	Maps attack category to expected rule ID and observed rule ID.

Deliverable	Expected value
Source-IP comparison table	Compares Kali IP, router pre-NAT IP, and web-layer translated IP.
Detection-tuning notes	Explains which rules need regex changes, decoder changes, or log-format changes.
Case-management preparation	Selects level 12 and 13 alerts for future DFIR/IR case automation.

10 Conclusion

This week produced a clear improvement in detection engineering maturity. The previous report showed partial dashboard-level evidence, mainly for BOLA/IDOR vehicle-location behavior. This week, the custom Wazuh rule set is validated by two scripts. The broader regression test passed 21 out of 21 checks, and the focused rule test passed 23 out of 23 checks. This proves that the implemented XML rules can match the intended Wazuh logtest inputs and produce the correct final rule IDs.

The main unresolved issue is live source-IP preservation. The lab should identify the Kali attacker as 10.10.1.20, but the web-layer logs currently show 172.20.0.2. This is a network logging and NAT visibility issue, not a rule-pattern failure. Until this is fixed, source-based correlation and attacker attribution should be treated as incomplete. The next engineering priority is to collect pre-NAT router logs or redesign the proxy/routing/logging path so that the original attacker IP is preserved.

Overall, the project is progressing correctly. Rule logic is validated. The detection scope is broader than last week. The remaining work is to improve evidence quality, preserve the original source IP, and then rerun live attacks to produce dashboard-confirmed evidence for every detection category.

A Appendix: Evidence Summary

A.1 Key Rule-Test Commands

Listing A.1: Commands used this week

```
cd ~/Lab_Security/wazuh-lab/single-node
./test_bglobal_wazuh_rules.sh
./test_mynew_rule.sh
```

A.2 Recommended Dashboard Fields

Listing A.2: Fields to capture in Wazuh Dashboard Discover

```
agent.name
agent.ip
data.srcip
data.id
data.protocol
data.url
rule.id
rule.level
rule.description
full_log
```

A.3 Source-IP Verification Checklist

Table A.1: Checklist for source-IP verification

No.	Check	Expected result
1	Send a request from Kali 10.10.1.20 to 10.10.1.1:8888.	Request reaches crAPI.
2	Inspect router pre-NAT log.	Log contains SRC=10.10.1.20.
3	Inspect web access log.	If it still shows 172.20.0.2, document it as translated.
4	Confirm Wazuh receives router log.	Rule 111000 fires.

No.	Check	Expected result
5	Confirm Kali-specific router rule.	Rule 1 1 1 0 10 fires when SRC=10.10.1.20.
6	Correlate router and web logs by timestamp.	Analyst can link true source IP to API endpoint.

B Appendix: Rule Coverage Matrix for Report Evidence

Table B.1: Final evidence matrix to fill after live retesting

Attack category	Expected rule	Live status	Evidence needed
BOLA numeric object access	110100/110104/110105	Pending live recheck	Dashboard row with URL, status, source IP, and rule ID.
BOLA repeated object access	110101	Pending live recheck	At least 10 object events within 300 seconds from same original source.
UUID vehicle-location access	110120/110121	Partially known from previous dashboard evidence	Row-level screenshot confirming exact rule ID.
UUID vehicle-location enumeration	110122	Pending live recheck	At least 5 vehicle-location events within 120 seconds from same original source.
REST method abuse	110130/110131	Pending live recheck	DELETE/PATCH/PUT request row and rule ID.
BFLA/admin probing	110400/110401/110402	Pending live recheck	Admin/internal/management endpoint row and correlation evidence.
Sensitive path probing	110102/110106/110107/110103	Pending live recheck	Path such as <code>/.env</code> or <code>/swagger</code> ; include status code.
Authentication abuse	110200/110201/110204/110205	Pending live recheck	Failed login/scanning events with correlation evidence.
SSRF	110300/110301	Pending live recheck	URL-visible private/loopback indicator, or add body/WAF log for POST payload.
SQLi/NoSQLi	110310/110311	Pending live recheck	Query string with injection token and observed rule ID.
JWT bypass heuristic	110500/110501	Pending live recheck	Visible <code>alg:none</code> or safe masked Authorization/header logging.
Mass Assignment/BOPLA	110510/110511	Pending live recheck	Visible suspicious property field in URL/query or safe body log.
Router source-IP visibility	111000/111001/111010	Main blocker	Pre-NAT log proving <code>SRC=10.10.1.20</code> .

References

1. Previous weekly report: *Week Report - Detection Engineering and Validation Phase*, SOC lab detection engineering report, 2026.
2. Project evidence file: `bglobal_crapi_rules.xml`, custom Wazuh rules for crAPI and bGlobal API detection use cases.
3. Project evidence file: `test_bglobal_wazuh_rules.sh` and `test_mynew_rule.sh`, Wazuh rule-test outputs showing 21/21 and 23/23 passing results.
4. OWASP API Security Top 10 - 2023, used as the conceptual mapping for API broken access control, authorization, SSRF, and injection-related testing.
5. MITRE ATT&CK, used for behavior mapping such as public-facing application exploitation, active scanning, brute force, and use of alternate authentication material.
6. Wazuh documentation, used as the operational reference for custom XML rules, rule levels, decoders, and correlation options.